



CÁTEDRA INCIBE
Digitalización y Ciberseguridad Hídrica

Características esenciales de la Directiva NIS2

(Directiva NIS2 (UE) 2022/2555) en relación con el sector del agua

Dra. Laura Arantegui Arràez

Dr. Steven Kemp

Dr. Ignasi Rodriguez-Roda Layret



ÍNDICE

1. ¿CUÁL ES EL OBJETIVO DE LA DIRECTIVA NIS2?	3
2. ¿CUÁNDO SE TRANSPONE LA DIRECTIVA AL ORDENAMIENTO JURÍDICO ESPAÑOL?	3
3. ¿A QUÉ ENTIDADES AFECTA LA NIS2 EN EL SECTOR DEL AGUA?	4
3.1. ¿CÓMO SE DEFINEN LAS “AGUAS POTABLES” Y LAS “AGUAS RESIDUALES”?	4
3.2. ¿CÓMO SE DEFINEN LAS “ENTIDADES ESENCIALES” Y LAS “ENTIDADES IMPORTANTES”? (ART. 3, APS. 1 Y 2)	5
3.2.a. <i>Entidades esenciales:</i>	5
3.2.b. <i>Entidades importantes:</i>	6
3.3. ¿CÓMO SE COMUNICARÁ LA CLASIFICACIÓN RESULTANTE EN “ENTIDADES ESENCIALES” Y “ENTIDADES IMPORTANTES”? (ART. 3.3)	6
3.4. ¿AFECTA LA NIS2 A ENTIDADES QUE PUEDEN SER CONSIDERADAS PEQUEÑAS EMPRESAS?	7
3.5. ¿CUÁLES SON LAS ENTIDADES INVOLUCRADAS EN LA CADENA DE SUMINISTRO DE AGUA AFECTADAS DE FORMA DIRECTA E INDIRECTA POR LA NIS2?	7
4. ¿QUÉ OBLIGACIONES DE COMUNICACIÓN CONLLEVA LA NIS2 PARA LAS ENTIDADES AFECTADAS? (ART. 21)	8
4.1. DEFINICIONES	8
4.2. COMUNICACIÓN AL CSIRT CORRESPONDIENTE O LA AUTORIDAD COMPETENTE:	9
4.3. COMUNICACIÓN A LOS DESTINATARIOS DE LOS SERVICIOS OFRECIDOS:	10
5. ¿QUÉ OBLIGACIONES EXISTEN EN CUANTO A TOMAR MEDIDAS DE CIBERSEGURIDAD?.- ¿QUÉ IMPLICA SEGURIDAD EN LA CADENA DE SUMINISTRO EN EL SECTOR DEL AGUA?	10
5.1. OBLIGACIONES GENERALES EN CUANTO A MEDIDAS DE CIBERSEGURIDAD (ART. 21)	10
5.2. LA CIBERSEGURIDAD EN EL SECTOR DEL AGUA	11
6. ¿QUÉ FORMAS DE SUPERVISIÓN SE EMPLEARÁN POR PARTE DE LAS AUTORIDADES?	13
6.1. SUPERVISIÓN DE ENTIDADES ESENCIALES (ART. 32)	13
6.2. SUPERVISIÓN DE ENTIDADES IMPORTANTES (ART. 33)	13
7. ¿CÓMO PUEDO DEMOSTRAR EL CUMPLIMIENTO DE LA DIRECTIVA? CERTIFICACIONES (ART. 24)	13
8. ¿QUÉ CONSECUENCIAS CONLLEVA NO CUMPLIR CON LAS OBLIGACIONES DE LA NIS2?	14
8.1. CONSECUENCIAS DE INCUMPLIMIENTO PARA ENTIDADES ESENCIALES (ART. 32):	15
8.2. CONSECUENCIAS DE INCUMPLIMIENTO PARA ENTIDADES IMPORTANTES (ART. 33)	15
8.3. MULTAS ADMINISTRATIVAS (ART. 34)	16
8.4. INCUMPLIMIENTOS QUE CONLLEVAN UNA VIOLACIÓN DE LA SEGURIDAD DE LOS DATOS PERSONALES (ART. 35)	17
9. ¿QUÉ HACER SI NECESITO MÁS INFORMACIÓN?	18



La Directiva europea NIS2, que entró en vigor el 16 de enero de 2023, representa un cambio fundamental en la gestión de la ciberseguridad de los países miembros de la UE. Es un avance decisivo hacia un enfoque más global y, en esencia, hacia una colaboración creciente entre todos los actores implicados para enfrentarse a los nuevos retos que plantea la lucha contra la ciberdelincuencia.

Los Estados miembros tienen hasta el 17 de octubre de 2024 para transponer la directiva a los ordenamientos jurídicos nacionales. Ante esta inminente transposición, muchas de las entidades españolas que entrarán en el ámbito de aplicación de la Directiva deberán realizar cambios relevantes en las medidas para la gestión de riesgos de ciberseguridad para cumplir con los estándares requeridos. Este informe pretende resumir los elementos esenciales para comprender el contenido de la Directiva NIS2 y valorar su posible impacto en las entidades del sector del agua afectadas.

Cabe subrayar que la transposición de la NIS2 al ordenamiento jurídico español proporcionará mayor claridad sobre los requisitos. Mientras tanto, este informe sirve para orientar las entidades del sector del agua sobre las posibles obligaciones que vendrán.

1. ¿Cuál es el objetivo de la Directiva NIS2?

La revisión de la Directiva (UE) 2016/1148 (NIS1) reveló grandes diferencias entre los Estados miembros respecto a la gestión de la ciberseguridad, ya que únicamente definía normas mínimas sobre un marco regulador coordinado y otros aspectos como los mecanismos de cooperación y las medidas de ejecución orientadas al cumplimiento de las obligaciones establecidas.

Por tanto, el objetivo de la NIS2 es “Ampliar el ámbito de aplicación por sectores a una parte más extensa de la economía para ofrecer una cobertura completa de los sectores y servicios de vital importancia para las actividades sociales y económicas fundamentales dentro del mercado interior” (Considerandos, 6).

2. ¿Cuándo se transpone la Directiva al ordenamiento jurídico español?

Como muy tarde el 17 de octubre de 2024, los Estados miembros adoptarán y publicarán las medidas necesarias para dar cumplimiento a lo establecido en la NIS2. Comunicarán inmediatamente a la Comisión el texto de dichas disposiciones, y las aplicarán a partir del 18 de octubre de 2024.



3. ¿A qué entidades afecta la NIS2 en el sector del agua?

A diferencia de la NIS1, (UE) 2016/1148, que solamente involucraba al sector del **agua potable**, la NIS2 incluye las **aguas residuales**. Ambas actividades se consideran “de alta criticidad” (Anexo I). Las entidades afectadas se definen como sigue:

SECTOR	TIPO DE ENTIDAD
6. Agua potable^(*)	Suministradores y distribuidores de aguas destinadas al consumo humano, tal como se definen en el artículo 2, punto 1, letra a), de la Directiva (UE) 2020/2184 del Parlamento Europeo y del Consejo, de 16 de diciembre de 2020, relativa a la calidad de las aguas destinadas al consumo humano (DO L 435 de 23.12.2020, p. 1)⁽¹⁾. <i>(*) Excluidos los distribuidores para los que la distribución de aguas destinadas al consumo humano sea una parte no esencial de su actividad general de distribución de otros bienes y productos básicos.</i>
7. Aguas residuales^(**)	Empresas dedicadas a la recogida, la eliminación o el tratamiento de aguas residuales urbanas, domésticas o industriales, tal como se definen en el artículo 2, puntos 1 a 3, de la Directiva 91/271/CEE del Consejo, de 21 de mayo de 1991, sobre el tratamiento de las aguas residuales urbanas (DO L 135 de 30.5.1991, p. 40)⁽²⁾. <i>(**) Excluidas las empresas para las que la recogida, la eliminación o el tratamiento de aguas residuales urbanas, domésticas o industriales sea una parte no esencial de su actividad general.</i>

3.1. ¿Cómo se definen las “aguas potables” y las “aguas residuales”?

Según las normas citadas en el Anexo I de la NIS2 y referidas a los sectores 6 y 7, se definen como sigue:

Aguas potables:



⁽¹⁾ *“Aguas destinadas al consumo humano: todas aquellas aguas, ya sea en su estado original, ya sea después del tratamiento, utilizadas para beber, cocinar, preparar alimentos y otros usos domésticos, en locales tanto públicos como privados, sea cual fuere su origen e independientemente de que se suministren a través de una red de distribución, de una cisterna o envasadas en botellas u otros recipientes, incluidas las aguas de manantial.*

Aguas residuales:

- ⁽²⁾ a) *« Aguas residuales urbanas » : las aguas residuales domésticas o la mezcla de las mismas con aguas residuales industriales y/o aguas de corriente pluvial.*
- b) *« Aguas residuales domésticas » : las aguas residuales procedentes de zonas de vivienda y de servicios y generadas principalmente por el metabolismo humano y las actividades domésticas.*
- c) *« Aguas residuales industriales » : todas las aguas residuales vertidas desde locales utilizados para efectuar cualquier actividad comercial o industrial, que no sean aguas residuales domésticas ni aguas de corriente pluvial.*

Mientras que la NIS1 dejaba al criterio de los Estados miembros decidir si una entidad podía ser considerada operadora de servicios esenciales, la NIS2 introduce para todos los sectores una clasificación (que sustituye a la anterior) entre entidades esenciales y entidades importantes, e incorpora un baremo común para realizar dicha clasificación.

3.2. ¿Cómo se definen las “entidades esenciales” y las “entidades importantes”? (art. 3, aps. 1 y 2)

Dentro de los sectores de agua potable y aguas residuales, la Directiva afecta a las entidades definidas como “esenciales” o “importantes. En general, esto viene a decir entidades grandes y medianas, aunque la NIS2 puede generar obligaciones para entidades de cualquier tamaño en ciertos casos concretos. Esta clasificación se establece como sigue:

3.2.a. Entidades esenciales:

- 1) Las que ocupan a 250 personas o más, o cuyo volumen anual de negocios supera los 50 millones de euros, o cuyo balance general anual supera los 43 millones de euros.
- 2) Con independencia del tamaño, las que el Estado miembro considere así en función del art.2.2.b) a e) de la Directiva es decir, si se da el caso de que:



- a) la entidad sea el único proveedor en un Estado miembro de un servicio esencial para el mantenimiento de actividades sociales o económicas críticas.
 - b) una perturbación del servicio prestado por la entidad pudiera tener repercusiones significativas sobre la seguridad pública, el orden público o la salud pública, o pudiera inducir riesgos sistémicos significativos, en particular para los sectores en los que tal perturbación podría tener repercusiones de carácter transfronterizo.
 - c) la entidad sea crítica a la luz de su importancia específica a nivel nacional o regional para el sector o tipo de servicio en concreto o para otros sectores interdependientes en el Estado miembro.
- 3) A criterio del Estado miembro, entidades del sector 6 (Agua potable) ya identificadas por dicho Estado miembro antes del 16 de enero de 2023 como operadores de servicios esenciales de conformidad con la Directiva (UE) 2016/1148 o el Derecho nacional.

3.2.b. Entidades importantes:

- 1) Empresas que ocupan a 50 personas o más, o cuyo volumen anual de negocio supera los 10 millones de euros.
- 2) Con independencia del tamaño, las que el Estado miembro identifique como tales en virtud del artículo 2 de la Directiva (como hemos visto antes).

Asimismo, se establece que la Comisión, en cooperación con el Grupo de Cooperación y tras consultar a las partes interesadas pertinentes, debe proporcionar directrices para evaluar si las pequeñas empresas y las microempresas están comprendidas en el ámbito de la Directiva.

3.3. ¿Cómo se comunicará la clasificación resultante en “entidades esenciales” y “entidades importantes”? (art. 3.3)

La identificación de las entidades afectadas como “esenciales” o “importantes” estará a cargo:

- a) De cada entidad si el Estado establece mecanismos para que se inscriban ellas mismas.
- b) Del Estado si no se establecen mecanismos de auto-inscripción. Esta es la opción más probable en España y, en ese caso, el Estado deberá solicitar a las entidades que presenten al menos la siguiente información a las autoridades competentes:



- El nombre de la entidad.
- La dirección y los datos de contacto actualizados, incluidas las direcciones de correo electrónico, los rangos de IP y los números de teléfono.
- Si procede, el sector y el subsector pertinentes a que se refieren los anexos I o II de la Directiva (Anexo I en el caso del sector del agua).
- Si procede, una lista de los Estados miembros en los que prestan servicios comprendidos en el ámbito de aplicación de la presente Directiva.

El 17 de abril de 2025 es la fecha límite para que los Estados miembros elaboren una lista de las entidades esenciales e importantes, la cual será revisada y, si es necesario, actualizada cada dos años.

3.4. ¿Afecta la NIS2 a entidades que pueden ser consideradas pequeñas empresas?

Según el considerando 56 de la Directiva, las pequeñas y medianas empresas son cada vez más el objetivo de ataques a la cadena de suministro debido a que, por sus características específicas, realizan una menor inversión en medidas de ciberseguridad. Por este motivo, en el considerando 85 se indica que los Estados miembros deberían promover que las entidades esenciales e importantes incorporaran medidas de gestión de riesgos de ciberseguridad en los acuerdos contractuales con sus proveedores directos y proveedores de servicios.

Asimismo, tal y como se detalla en el art. 21.2.d), una de las medidas obligatorias para las entidades esenciales e importantes es la ciberseguridad en la cadena de suministro. Por tanto, las entidades pequeñas no entran en el alcance general de la NIS2 de forma directa, pero puede ser que las entidades obligadas con arreglo a la Directiva impongan ciertas obligaciones a sus entidades proveedores para cumplir con la misma. El alcance de los acuerdos y obligaciones mencionados, así como la delimitación de responsabilidad de las partes son aspectos que no están especificados en la NIS2, pero se prevé que todas las entidades que participan en la cadena de suministro del agua tendrán que cumplir con algunas obligaciones mínimas en materia de ciberseguridad.

3.5. ¿Cuáles son las entidades involucradas en la cadena de suministro de agua afectadas de forma directa e indirecta por la NIS2?

a) Respecto al agua potable:

- Las plantas de tratamiento del agua, donde es tratada para cumplir con los estándares de calidad.



- Las entidades de control sanitario que verifican la potabilidad del agua para garantizar la salud pública.
- Las entidades que gestionan, directamente o por concesión, la distribución del agua potable.

b) Respecto a las aguas residuales:

- Los sistemas de alcantarillado, que recogen y transportan las aguas residuales.
- Las plantas de tratamiento de aguas residuales, donde se eliminan las sustancias contaminantes que puedan contener.
- Las entidades de control sanitario que verifican que las aguas residuales estén en condiciones que no pongan en peligro la salud pública y ambiental.

c) Entidades que pueden estar indirectamente afectadas¹ (a título de ejemplo):

- En el ámbito del hardware, ingenierías y consultorías que participan en proyectos de construcción de infraestructuras como las depuradoras.
- En el ámbito del software, empresas proveedoras de alojamiento de datos en la nube, servicios de encriptación de datos, de programas de ciberseguridad como los antivirus, etc.

4. ¿Qué obligaciones de comunicación conlleva la NIS2 para las entidades afectadas? (art. 21)

4.1. Definiciones

El art. 6 de la NIS2 establece una serie de definiciones para los posibles incidentes (“cuasiincidente”, “incidente”, “ciberamenaza significativa”, etc.) que clarifican el alcance de las previsiones normativas. Asimismo, es importante la definición de “incidente significativo” (art. 23.3), que es aquel que:

¹ Entran en este grupo las empresas que, aun no estando en el ámbito de aplicación de esta Directiva, intervienen en la cadena de suministro del agua mediante contratos y servicios ofrecidos a las entidades que sí están directamente afectadas por la NIS2. Las implicaciones de la normativa para estas empresas quedarán definidas a partir de la transposición de la Directiva.



- a) Ha causado o puede causar graves perturbaciones operativas de los servicios o pérdidas económicas para la entidad afectada.
- b) Ha afectado o puede afectar a otras personas físicas o jurídicas al causar perjuicios materiales o inmateriales considerables.

Dos ejemplos reales de incidentes potencialmente significativos son:

1. El acceso a un número elevado de contadores de agua de lectura remota y la alteración fraudulenta de la lectura.
2. El acceso a los sistemas de depuración modificando el volumen de alguno de los componentes añadidos al agua y con ello poniendo en riesgo la salud de la población afectada.

En virtud de dichas definiciones, se establecen las siguientes obligaciones de comunicación por parte de las entidades afectadas, tanto a las autoridades competentes como a los usuarios (art. 23):

4.2. Comunicación al CSIRT correspondiente o la autoridad competente:

- Incidente: Cualquier incidente significativo en la prestación de sus servicios.
- Plazo:
 - 24h h desde que se haya tenido constancia del incidente significativo: una alerta temprana en la que se indicará si cabe sospechar que responde a una acción ilícita o malintencionada o puede tener repercusiones transfronterizas.
 - 72 h desde que se haya tenido constancia del incidente: una notificación actualizando, si procede, la alerta temprana, y exponiendo una evaluación inicial del incidente significativo (gravedad, impacto e indicadores de compromiso, si se dispone de ellos).
 - Con carácter intermedio: si el CSIRT o la autoridad competente lo solicitan, un informe actualizado de la situación.
 - Como muy tarde 1 mes después de presentar la notificación de las 72 h, un informe final que contenga:
 - Una descripción detallada del incidente (incluyendo gravedad e impacto).
 - El tipo de amenaza o causa principal probable.
 - Las medidas paliativas aplicadas y en curso.



- Las repercusiones transfronterizas del incidente, si procede.

4.3. Comunicación a los destinatarios de los servicios ofrecidos:

- Incidente: Ciberamenazas significativas e incidentes significativos susceptibles de afectar negativamente a la prestación de dichos servicios.
- Destinatarios de la comunicación:
 - Los que puedan verse afectados por una ciberamenaza significativa (se les comunicarán las medidas o soluciones que pueden aplicar en respuesta a la amenaza y, si procede, se les comunicará la propia ciberamenaza significativa).
 - El público en general: cuando la divulgación sea necesaria para evitar o hacer frente a un incidente significativo o sea de interés público. En este caso, la comunicación la podrán hacer también los CSIRT o las autoridades competentes, después de consultarlo con la entidad afectada o de exigirle sin éxito que lo haga.
- Plazo: Sin demora indebida.

El mero acto de notificar no elevará la responsabilidad de la entidad notificante.

Asimismo, el art. 30 de la Directiva establece la importancia de que las comunicaciones sean voluntarias y las realicen todo tipo de entidades, también las no afectadas por la norma legal.

5. ¿Qué obligaciones existen en cuanto a las medidas de ciberseguridad?.- ¿Qué implica ciberseguridad en la cadena de suministro en el sector del agua?

5.1. Obligaciones generales en cuanto a medidas de ciberseguridad (art. 21)

Las Entidades deberán tomar medidas técnicas, operativas y de organización adecuadas y proporcionadas para gestionar los riesgos que puedan afectar la seguridad de sus sistemas de redes y de información. Las medidas deberán ser proporcionales al grado de exposición de la entidad a los riesgos, el tamaño de la entidad y la probabilidad de que se produzcan incidentes y su gravedad, incluidas sus repercusiones sociales y económicas. Las medidas incluirán al menos los siguientes elementos:

- a) Las políticas de seguridad de los sistemas de información y análisis de riesgos.
- b) La gestión de incidentes.



- c) La continuidad de las actividades, como la gestión de copias de seguridad y la recuperación en caso de catástrofe, y la gestión de crisis.
- d) La seguridad de la cadena de suministro, incluidos los aspectos de seguridad relativos a las relaciones entre cada entidad y sus proveedores o prestadores de servicios directos. Para ello deberán tenerse en cuenta las vulnerabilidades específicas de cada proveedor y prestador de servicios directo y la calidad general de los productos y las prácticas en materia de ciberseguridad de sus proveedores y prestadores de servicios, incluidos sus procedimientos de desarrollo seguro. Las entidades deben tener en cuenta los resultados de las evaluaciones coordinadas de los riesgos de seguridad de las cadenas de suministro críticas que puede llevar a cabo el Grupo de Cooperación, en colaboración con la Comisión y la ENISA.
- e) La seguridad en la adquisición, el desarrollo y el mantenimiento de sistemas de redes y de información, incluida la gestión y divulgación de las vulnerabilidades.
- f) Las políticas y los procedimientos para evaluar la eficacia de las medidas para la gestión de riesgos de ciberseguridad.
- g) Las prácticas básicas de ciberhigiene y formación en ciberseguridad.
- h) Las políticas y procedimientos relativos a la utilización de criptografía y, en su caso, de cifrado.
- i) La seguridad de los recursos humanos, las políticas de control de acceso y la gestión de activos.
- j) El uso de soluciones de autenticación multifactorial o de autenticación continua, comunicaciones de voz, vídeo y texto seguras y sistemas seguros de comunicaciones de emergencia en la entidad, cuando proceda.

5.2. La ciberseguridad en el sector del agua

En el ámbito de ciberseguridad hídrica, la cadena de suministro del agua potable requiere unas medidas que garanticen que el agua potable suministrada sea segura para el consumo humano, y un fallo en la ciberseguridad puede tener consecuencias inmediatas para la salud pública. En el caso de las aguas residuales, un fallo puede también resultar en problemas de salud pública pero las consecuencias pueden ser menos inmediatas y directas que en el suministro de agua potable. Debe añadirse, otros riesgos como la prevención de daños ambientales o la protección de datos de clientes y consumidores.

Las medidas de ciberseguridad a implementar pueden considerarse comunes a ambas cadenas de distribución y el ciclo del agua en general. Algunas de las medidas de protección y seguridad destacables en el ámbito del agua son:



a) Seguridad física y perimetral de las infraestructuras críticas. La seguridad física es indisoluble de la ciberseguridad.

b) Control de procesos y de los denominados Sistemas SCADA (Supervisory Control and Data Acquisition), para asegurar la integridad y disponibilidad de los sistemas de control que gestionan el tratamiento y distribución del agua potable. Ello puede implicar diversas medidas:

b1) Seguridad en Redes y Sistemas: segmentación de redes (separando las redes de tecnología operativa (OT) de las redes de tecnología de la información (IT) para limitar el acceso a sistemas críticos), autenticación multifactor y cifrado de comunicaciones. Firewalls y sistemas de detección de intrusos. Control de la seguridad de todos los dispositivos conectados a una red.

b2) Protección de Sistemas de Control: Aislamiento de sistemas SCADA, asegurar dichos sistemas mediante autenticación robusta, cifrado de datos y actualización regular de software. Implementar políticas de control de acceso basadas en roles para restringir el acceso a sistemas críticos solo a personal autorizado. Aplicar el principio de privilegio mínimo, donde los usuarios solo tienen los permisos necesarios para realizar su trabajo. Realizar revisiones periódicas de los permisos de acceso y ajustarlos según sea necesario.

b3) Monitoreo y detección de amenazas: Uso de herramientas de monitoreo continuo y en tiempo real para detectar actividades sospechosas y responder rápidamente a incidentes de seguridad. Implementar soluciones de análisis de comportamiento para identificar patrones anómalos que puedan indicar una amenaza cibernética. Implementar soluciones SIEM (Security Information and Event Management) para centralizar y analizar los registros de seguridad. Establecer sistemas de alerta temprana para notificar rápidamente cualquier intento de intrusión o actividad sospechosa.

b4) Gestión de vulnerabilidades: Actualizaciones permanentes de seguridad en todos los sistemas y aplicaciones. Evaluaciones de seguridad periódicas para identificar vulnerabilidades.

b5) Diseño de respuestas a los incidentes: A través de planes de contingencia, copias de seguridad de datos, simulacros de ciberincidentes, coordinación con agencias gubernamentales y participación en iniciativas de intercambio de información sobre amenazas cibernéticas con otras entidades del sector y organismos de ciberseguridad.

b6) Acciones con el personal de las entidades: Capacitación mediante prácticas de ciberseguridad y concienciación sobre riesgos y mejores prácticas preventivas. Participación en los simulacros de incidentes.



6. ¿Qué formas de supervisión se emplearán por parte de las autoridades?

6.1. Supervisión de entidades esenciales (art. 32)

Las autoridades competentes podrán someter a las entidades esenciales, a priori y como mínimo, a:

- a) Inspecciones *in situ* y supervisión a distancia, incluidos controles aleatorios realizados por profesionales cualificados.
- b) Auditorías de seguridad periódicas y específicas llevadas a cabo por un organismo independiente o una autoridad competente, y *ad hoc* en casos concretos, si procede.
- d) Análisis de seguridad basados en criterios de evaluación del riesgo objetivos, con la cooperación de la entidad afectada cuando sea necesario.
- e) Solicitudes de información necesaria para evaluar las medidas para la gestión de riesgos de ciberseguridad adoptadas por la entidad afectada, solicitudes de acceso a datos e información, y solicitudes de pruebas de la aplicación de las políticas de ciberseguridad.

6.2. Supervisión de entidades importantes (art. 33)

Las medidas de supervisión aplicables a las entidades importantes se realizarán *a posteriori* si hay indicios de que presuntamente no cumplen la Directiva. Podrá someterse a dichas entidades, como mínimo, a:

- a) Inspecciones *in situ* y supervisión *a posteriori* a distancia a cargo de profesionales cualificados.
- b) Auditorías de seguridad específicas que efectuará un organismo independiente o una autoridad competente.
- c) Análisis de seguridad basados en criterios de evaluación del riesgo objetivos, con la cooperación de la entidad afectada cuando sea necesario.
- d) Solicitudes de información necesaria para evaluar *a posteriori* las medidas para la gestión de riesgos de ciberseguridad adoptadas por la entidad afectada, solicitudes de acceso a datos e información, y solicitudes de pruebas de la aplicación de las políticas de ciberseguridad.

7. ¿Cómo puedo demostrar el cumplimiento de la Directiva? Certificaciones (art. 24)



Los Estados miembros podrán exigir a las entidades esenciales e importantes que utilicen productos, servicios y procesos de TIC particulares, desarrollados por las entidades mismas o adquiridos a terceros, que estén certificados en virtud de un esquema europeo de certificación de la ciberseguridad adoptado según el artículo 49 del Reglamento (UE) 2019/881.

En España, la autoridad nacional de certificación de la ciberseguridad es el CCN (Centro Criptográfico Nacional).

Cuando se hayan detectado niveles insuficientes de ciberseguridad, la Comisión estará facultada para adoptar actos delegados especificando qué categorías de entidades esenciales e importantes están obligadas a utilizar determinados productos, servicios o procesos de TIC certificados o a obtener una certificación en virtud de un esquema europeo de certificación de la ciberseguridad.

Aunque no existe una norma internacional de certificación específica para el sector del agua, entre las existentes pueden emplearse las siguientes:

- ISO/IEC 27001, ampliamente aceptada en Europa para la gestión de la seguridad de la información.
- ISO/IEC 27019:2017 (una extensión de la anterior), con directrices específicas para la implementación de controles de seguridad de la información en sistemas de control industrial.
- IEC 62443, centrada en la ciberseguridad para sistemas de control y automatización industrial.
- En España, el Esquema Nacional de Seguridad (ENS), regulado por el Real Decreto 311/2022, de 3 de mayo, ha elaborado un Perfil de Cumplimiento Específico (PCE-NIS2) para ajustarse a los requisitos de la Directiva². El Centro Criptológico Nacional prevé la posibilidad de que a partir de la transposición de la Directiva deban hacerse algunas modificaciones al PCE. Asimismo, las organizaciones que se consideren de riesgo alto deberán ajustarse a requisitos más exigentes del ENS que los determinados en el PCE.

8. ¿Qué consecuencias conlleva no cumplir con las obligaciones de la NIS2?

El incumplimiento de las obligaciones de seguridad (art. 21) y comunicación (art. 23) por parte de las entidades afectadas podrá conllevar diversas consecuencias.

² Disponible en: <https://www.ccn-cert.cni.es/es/800-guia-esquema-nacional-de-seguridad/7235-ccn-stic-892-perfil-de-cumplimiento-especifico-para-organizaciones-en-el-ambito-de-aplicacion-de-la-directiva-nis2-pce-nis2/file.html>



8.1. Consecuencias de incumplimiento para entidades esenciales (art.32):

Las autoridades competentes podrán, como mínimo:

- a) Apercibir a las entidades afectadas.
- b) Adoptar instrucciones vinculantes, como medidas para prevenir o subsanar un incidente, plazos de ejecución de las mismas u órdenes de requerimiento para subsanar deficiencias o incumplimientos.
- c) Exigir que cesen las infracciones de la Directiva y que no se repitan, así como exigir la garantía de adecuación a las previsiones y el cumplimiento efectivo de la Directiva en modo y plazo específicos.
- d) Ordenar que se apliquen en un plazo concreto las recomendaciones derivadas de una auditoría de seguridad, y también que se hagan públicos determinados aspectos del incumplimiento de la Directiva de una manera específica.
- e) Imponer o solicitar la imposición por parte de los organismos u órganos jurisdiccionales competentes de una multa administrativa a título adicional respecto de cualquiera de las medidas anteriores.

Si las medidas requeridas no se adoptan dentro del plazo establecido, la autoridad competente podrá:

- a) Ordenar o solicitar la suspensión temporal de la certificación o autorización referente a una parte o la totalidad de los servicios o actividades prestados por la entidad.
- b) Solicitar la prohibición temporal del ejercicio de las funciones del director general o representante legal de la entidad por parte de quien ostente ese cargo.

Cualquier persona física responsable de una entidad esencial o que actúe como representante de ella con facultades para representarla, la autoridad para tomar decisiones en su nombre o la autoridad para ejercer control sobre ella tendrá competencias para velar por que cumpla la Directiva. Las personas físicas podrán considerarse responsables por el incumplimiento de su deber de garantizar el cumplimiento de la Directiva.

Las suspensiones o las prohibiciones temporales impuestas se aplicarán únicamente hasta que la entidad afectada adopte las medidas necesarias.

8.2. Consecuencias de incumplimiento para entidades Importantes (art. 33)

Las autoridades competentes podrán, como mínimo:

- a) Apercibir a las entidades afectadas.



- b) Adoptar instrucciones vinculantes u órdenes de requerimiento para subsanar deficiencias o incumplimientos.
- c) Ordenar que cesen las infracciones de la Directiva y que no se repitan, así como ordenar que la garantía de adecuación a las previsiones y el cumplimiento efectivo de la Directiva en modo y plazo específicos.
- d) Ordenar que se apliquen en un plazo razonable las recomendaciones derivadas de una auditoría de seguridad, y también que se hagan públicos determinados aspectos del incumplimiento de la Directiva de una manera específica.
- e) Imponer o solicitar la imposición por parte de los organismos u órganos jurisdiccionales competentes de una multa administrativa a título adicional respecto de cualquiera de las medidas anteriores.

8.3. Multas administrativas (art. 34)

Las multas administrativas se impondrán a título adicional respecto a cualquiera de las medidas antes contempladas. La cuantía de las multas se establece como sigue:

- a) Multas para entidades esenciales. La de mayor cuantía entre:
 - Un máximo de, al menos, 10 000 000 EUR, o
 - Un máximo de, al menos, el 2 % del volumen de negocios anual total a nivel mundial de la empresa a la que pertenece la entidad esencial durante el ejercicio financiero anterior.
- b) Multas para entidades importantes. La de mayor cuantía entre:
 - Un máximo de, al menos, 7 000 000 EUR, o
 - Un máximo de, al menos, el 1,4 % del volumen de negocios anual total a nivel mundial de la empresa a la que pertenece la entidad importante durante el ejercicio financiero anterior.

Asimismo, los Estados miembros podrán prever la facultad de imponer multas coercitivas para obligar a una entidad esencial o importante a poner fin a un incumplimiento de la presente Directiva de conformidad con una decisión previa de la autoridad competente.

A la hora de decidir la imposición de una multa administrativa y su cuantía en cada caso particular se tendrán debidamente en cuenta, como mínimo, los elementos siguientes (art. 32.7):

- a) La gravedad del incumplimiento y la importancia de las disposiciones infringidas. Entre otros, constituyen en todo caso incumplimientos graves:



- a1) Los incumplimientos reiterados.
- a2) La ausencia de notificación o subsanación de los incidentes significativos.
- a3) La ausencia de subsanación de deficiencias tras recibir instrucciones vinculantes de las autoridades competentes.
- a4) La obstrucción de las auditorías o actividades de control ordenadas por la autoridad competente tras la constatación de un incumplimiento.
- a5) El suministro de información falsa o manifiestamente imprecisa en relación con las medidas de gestión del riesgo de ciberseguridad o las obligaciones de notificación establecidas.
- b) La duración del incumplimiento.
- c) Todo incumplimiento anterior relevante cometido por la entidad afectada.
- d) Todo perjuicio material o inmaterial causado, incluidas las pérdidas financieras o económicas, los efectos para otros servicios y el número de usuarios afectados.
- e) Cualquier intencionalidad o negligencia por parte del autor del incumplimiento.
- f) Cualesquiera medidas adoptadas por la entidad para prevenir o reducir los perjuicios materiales o inmateriales.
- g) Cualquier adhesión a códigos de conducta o a mecanismos de certificación aprobados.
- h) El grado de cooperación de las personas físicas o jurídicas responsables con las autoridades competentes.

8.4. Incumplimientos que conllevan una violación de la seguridad de los datos personales (art. 35)

Si el incumplimiento de las obligaciones de comunicación y seguridad establecidas conlleva una violación de la seguridad de los datos personales tal y como se describe en el art. 4.12 del Reglamento Europeo de Protección de datos ((UE) 2016/679)³, las entidades afectadas informarán sin demora indebida a las autoridades de control a que se refieren los artículos 55 y 56 de dicho Reglamento. Cuando dichas autoridades de control impongan una multa administrativa en virtud del Reglamento, las autoridades competentes no impondrán una multa administrativa en virtud de la NIS2 por un incumplimiento derivado de la misma conducta. Las autoridades competentes podrán,

³ Violación de la seguridad de los datos personales»: toda violación de la seguridad que ocasione la destrucción, pérdida o alteración accidental o ilícita de datos personales transmitidos, conservados o tratados de otra forma, o la comunicación o acceso no autorizados a dichos datos.



no obstante, imponer las medidas de ejecución mencionadas anteriormente, exceptuando la multa administrativa.

9. ¿Qué hacer si necesito más información?

Para resolver dudas o solicitar más información sobre la aplicación de la NIS2, las entidades pueden dirigirse a:

- El texto completo de la Directiva:

<https://eur-lex.europa.eu/legal-content/ES/TXT/PDF/?uri=CELEX:32022L2555>

- La autoridad competente nacional sobre ciberseguridad (en España, el Instituto Nacional de Ciberseguridad -INCIBE-):

(<https://www.incibe.es/incibe-cert/sectores-estrategicos/FAQNIS2>).

- Los Equipos de Respuesta a Incidentes de Seguridad Informática (CSIRT) nacionales y sectoriales.

<https://www.csirt.es/index.php/es/>

- La Agencia de la Unión Europea para la Ciberseguridad (ENISA), que ofrece recursos, directrices y formación relacionados con la implementación de la Directiva NIS2, y publica informes y guías:

<https://www.enisa.europa.eu/topics/cybersecurity-policy/nis-directive-new>

- La página web del Consejo Europeo:

<https://www.consilium.europa.eu/es/policies/cybersecurity/>

- La página web de la Cátedra en Digitalización y Ciberseguridad Hídrica:

<https://www.cyberh2o.es/>

- Empresas de consultoría y auditoría especializadas en ciberseguridad.